

Fig. 3: Public key exchange

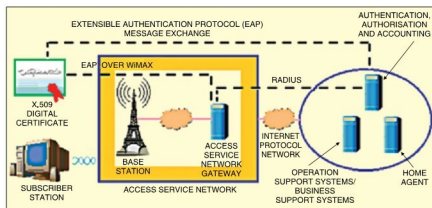


Fig. 4: Authentication using extensible authentication protocol

work. The security sub-layer employs an authenticated client/server key management protocol in which the base station server controls distribution of keying material to the client subscriber station. Additionally, the basic security mechanisms are strengthened by adding digital certificate-based subscriber station device authentication to the key management protocol.

Security components

WiMAX security uses two component protocols—encapsulation protocol and privacy key management (PKM) protocol. The encapsulation protocol is used for securing packet data across the wireless network. This protocol defines a set of supported cryptographic suites, i.e., pairings of data encryption and authentication algorithms and the rules for applying these algorithms to a MAC packet data unit payload.

On the other hand, the PKM protocol is used for secure distribution of keying data from the base station to the

subscriber station. Through this key management protocol, the subscriber station and the base station synchronise keying data. In addition, the base station uses the protocol to enforce conditional access to network services. The stack of security components of the system is shown in Fig. 2.

Key management protocol. There are two PKM protocols supported in IEEE Standard 802.16—PKM version 1 (PKMv1) and PKMv2 with more enhanced features such as new key hierarchy, advanced encryption standard (AES)-cipher message authentication code, AES-key-wraps, and multicast and broadcast services. PKM protocol allows mutual authentication, unilateral authentication, periodic re-authentication/re-authorisation and key refresh.

Key management protocol uses either extensible authentication protocol, or X.509 digital certificates together with Rivest-Shamir-Adleman (RSA) public-key encryption algorithm or a

sequence starting with RSA authentication and followed by extensible authentication protocol authentication. It uses strong encryption algorithms to perform key exchanges between a subscriber station and base station. RSA protocol support is mandatory in PKMv1 but optional in PKMv2. However, extensible authentication protocol support is optional in both the versions of key management protocol, unless specifically required.

PKM's authentication protocol establishes a shared secret, called authorisation key, between the subscriber station and base station. The shared secret is then used to secure subsequent PKM exchanges of traffic encryption keys. This two-tiered mechanism for key distribution permits refreshing of traffic encryption keys without incurring the overhead of computation-intensive operations.

The authorisation key is derived by the base station and subscriber station from the pre-authorisation key (in case of RSA-based authorisation procedure) and/or the PMK (in case of extensible authentication protocol-based authorisation procedure). The exclusive-or (XOR) value of primary authorisation key and pairwise master key is mainly used to generate the authorisation key. The Dot16KDF algorithm is used for authorisation key derivation.

The base station authenticates a client subscriber station during the initial authorisation exchange. Each subscriber station presents its credentials, which is a unique X.509 digital certificate issued by the subscriber station's manufacturer (in case of RSA authentication) or an operator-specified credential (in case of EAP-based authentication).

The base station associates the subscriber station's authenticated identity to a paying subscriber and hence to the data services that the subscriber is authorised to access. Thus, with the authorisation key exchange, the base station determines the authenticated identity of a client subscriber station and the services (i.e., specific traffic encryption keys) the subscriber station is authorised to access. Since the base station authen-